ESEN

C I B E R S E G U R I D A D

Proyecto Final · Entregable E.10

Roadmap de madurez hacia el IG asignado

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.10 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del equipo..... 3
2. Instrucciones de uso..... 3
3. Roadmap de madurez hacia el IG asignado..... 3
I.1 Plantilla del roadmap..... 4
I.2 Estado esperado por horizonte..... 7
I.3 Tratamientos de E.05 sin salvaguarda CIS..... 7
Supuestos declarados en este entregable..... 7
Horizontes, criterio de progresión y costo..... 8
Trazabilidad del roadmap..... 8

1. Identificación del equipo

Campo	Registro
Equipo	Nexo Crítico Consultores
Organización del catálogo	Energía Nacional S.A. de C.V. (ENSA) — perfil n.° 4
Grupo de Implementación asignado	IG3
Integrantes	Seis, con los cinco roles cubiertos
Fecha de entrega	miércoles 11 de noviembre de 2026 (H5)
Versión del documento	v1.0

2. Instrucciones de uso

- La plantilla se completa para la organización asignada al equipo en el Catálogo de Empresas 2026.
- La sección E.10 de la Guía del Estudiante del Proyecto Final describe el objetivo de este entregable, sus insumos, los pasos, el llenado campo por campo, un ejemplo resuelto, los errores frecuentes, el checklist de cierre y la fecha de entrega.
- Este archivo es el ejemplo resuelto con ENSA: conserva el formato, los encabezados y el pie de la plantilla en blanco, y muestra el nivel de detalle que el proyecto espera. El equipo trabaja sobre su propia plantilla y con su propia organización.
- Nombre del archivo de entrega en Moodle: E10_Roadmap_Madurez_IG_<Equipo>.docx (o .pdf).

3. Roadmap de madurez hacia el IG asignado

El roadmap ordena en el tiempo lo que el checklist de E.08 dejó como «por implementar» o «al roadmap», más las mejoras que la auditoría de E.09 anticipa, en tres horizontes. La progresión sigue los Grupos de Implementación: primero se consolida IG1 completo; después las salvaguardas IG2 e IG3 que el IG asignado exige, en el orden que las dependencias permiten; y el último horizonte completa las salvaguardas IG3 del baseline que quedan pendientes, hasta las 153 del Grupo de Implementación asignado. Criterio de progresión: una iniciativa entra al siguiente horizonte cuando sus dependencias del horizonte anterior están cubiertas.

Campo	Registro
Fecha de arranque del programa (ficha de datos del cliente)	Lunes 4 de enero de 2027

Horizonte	Alcance típico
Corto plazo (0–6 meses): 4 de enero a 30 de junio de 2027	Cierre de brechas IG1 detectadas en E.08 y estabilización de los seis controles desarrollados en E.07.
Mediano plazo (6–18 meses): 1 de julio de 2027 a 30 de junio de 2028	Salvaguardas IG2 del baseline aún pendientes: gestión centralizada de bitácoras, filtrado entre segmentos y gestión de incidentes ampliada, entre otras.
Largo plazo (18–36 meses): 1 de julio de 2028 a 31 de diciembre de 2029	Salvaguardas IG3 del baseline aún pendientes (p. ej. detección de intrusiones en red, pruebas de penetración periódicas, seguridad de aplicaciones) y madurez del programa hasta completar las 153 salvaguardas del IG3 asignado.

Ejemplo resuelto de cátedra · entrega: miércoles 11 de noviembre de 2026 (H5).

I.1 Plantilla del roadmap

Iniciativa	Salvaguardas CIS v8.1	IG	Horizonte	Responsable	Dependencias	Resultado esperado
Respaldo del entorno SCADA con copia aislada e inmutable y prueba trimestral de restauración	11.1, 11.2, 11.3, 11.4, 11.5	IG1 / IG2	Corto	Jefatura de TI/TO	Ninguna: es la brecha B-01 y encabeza el programa	Restauración verificada dentro del RTO de 2 h y del RPO de 15 min, con acta firmada por el dueño del proceso
Segmentación de los puntos de conexión TI–OT con zona intermedia y anfitrión de salto	12.2, 12.3, 12.4, 12.6	IG1 / IG2	Corto	Jefatura de TI/TO con Operaciones de Red	Diagramas de arquitectura actualizados	Cero rutas directas entre la red de TI y la red OT, verificadas con prueba de bloqueo trimestral
Autenticación multifactor en cuentas administrativas, acceso remoto y aplicaciones expuestas	6.1, 6.2, 6.3, 6.4, 6.5	IG1	Corto	Jefatura de TI/TO	Inventario de cuentas 5.1 en curso	100 % de las cuentas privilegiadas con segundo factor (IND-05)
Concentrador de acceso para proveedores con habilitación por sesión y grabación	6.4, 6.5, 15.4	IG1 / IG2	Corto	Jefatura de TI/TO con Cumplimiento	Renegociación del anexo de seguridad del contrato del fabricante	Cero sesiones de proveedor fuera de ventana autorizada (IND-06)
Inventario de activos de TI y de OT con descubrimiento pasivo	1.1, 1.2, 1.3, 1.4, 1.5	IG1 / IG2 / IG3	Corto	Jefatura de TI/TO	Sonda pasiva instalada en la zona intermedia	100 % de los activos de ambas redes registrados con dueño
Gestión de vulnerabilidades con ventanas de mantenimiento acordadas para OT	7.1, 7.2, 7.3, 7.4, 7.5, 7.6, 7.7	IG1 / IG2	Corto	Jefatura de TI/TO con Operaciones de Red	Inventario de activos y calendario de ventanas	Vulnerabilidades críticas remediadas dentro de 15 días en TI y con decisión registrada en OT (IND-07, IND-08)
Configuración segura con líneas base y retiro de credenciales de fábrica	4.1, 4.2, 4.3, 4.4, 4.5, 4.6, 4.7, 4.8, 4.9	IG1 / IG2	Corto	Jefatura de TI/TO	Inventario de activos	Líneas base aprobadas y desviaciones controladas; incluye el endurecimiento de los concentradores AMI que la tabla D.6 de E.05 recomendó absorber aquí
Programa de concientización y capacitación del personal	14.1 a 14.8	IG1	Corto	Recursos Humanos con la Jefatura de Seguridad	Ninguna	100 % del personal capacitado en el año, con módulo específico de suplantación asistida por IA
Inventario, clasificación y anexos de seguridad de proveedores	15.1, 15.2, 15.3, 15.4, 15.7	IG1 / IG2 / IG3	Corto	Cumplimiento con la Jefatura de Seguridad	Ninguna	100 % de los proveedores críticos con anexo firmado (IND-11)

Iniciativa	Salvaguardas CIS v8.1	IG	Horizonte	Responsable	Dependencias	Resultado esperado
Migración de los cortafuegos corporativos de FortiOS 7.2 a FortiOS 7.4	12.1	IG1	Corto	Jefatura de TI/TO	Ventana de mantenimiento acordada con Operaciones de Red	Cortafuegos con versión soportada por el fabricante y configurados con el CIS Benchmark de Fortinet FortiGate 7.4.x; FortiOS 7.2 terminó su soporte el 30 de septiembre de 2026 (hallazgo de E.07, control 12)
Sustitución de Windows 10 por Windows 11 en el parque heredado y software con soporte vigente	2.1, 2.2, 2.3	IG1	Corto	Jefatura de TI/TO	Inventario de activos	Ninguna estación de TI con sistema operativo sin soporte; Windows 10 22H2 perdió el soporte el 14 de octubre de 2025 (hallazgo de E.07, control 7), y las estaciones HMI con Windows 10 Enterprise LTSC 2019 lo conservan hasta el 9 de enero de 2029
Gestión de cuentas: inventario, contraseñas únicas, baja de cuentas inactivas y cuentas administrativas dedicadas	5.1, 5.2, 5.3, 5.4	IG1	Corto	Jefatura de TI/TO	Ninguna	Inventario de cuentas de TI y de OT con dueño, sin cuentas compartidas ni inactivas
Gestión de datos: inventario de datos, listas de acceso por repositorio, eliminación segura y cifrado de estaciones	3.2, 3.3, 3.5, 3.6	IG1	Corto	Jefatura de TI/TO con Gerencia Comercial	Inventario de activos de E.04	Inventario de datos con dueño y acceso revisado por repositorio; equipos dados de baja con acta de destrucción
Centralización de bitácoras y sincronización de tiempo entre TI y OT	8.1 a 8.5, 8.9, 8.10, 8.11	IG1 / IG2	Mediano	Jefatura de TI/TO	Plataforma de alertas del control 13 operando	Noventa días de bitácoras en línea, correlacionables entre las dos redes
Monitoreo de la red OT con detección pasiva y ajuste de umbrales	13.1, 13.3, 13.4, 13.6, 13.11	IG2 / IG3	Mediano	Jefatura de Seguridad de la Información	Segmentación implantada y bitácoras centralizadas	Alertas de severidad alta atendidas dentro de la hora (IND-04)
Gestión de respuesta a incidentes con ejercicios anuales	17.1 a 17.9	IG1 / IG2 / IG3	Mediano	Jefatura de Seguridad de la Información	Monitoreo operando y roles designados	Plan probado con un ejercicio anual sobre compromiso del entorno de control
Protección de datos: esquema de clasificación, cifrado en reposo y en tránsito, retención y flujos documentados	3.1, 3.4, 3.7, 3.8, 3.9, 3.10, 3.11, 3.12	IG1 / IG2	Mediano	Jefatura de TI/TO con Gerencia Comercial	Inventario de datos y clasificación aplicada	Datos personales de clientes cifrados y con retención declarada conforme a la LPDP
Protección de correo y navegación: filtrado, política de autenticación de correo y control de extensiones	9.2 a 9.7	IG1 / IG2 / IG3	Mediano	Jefatura de TI/TO	Programa de concientización iniciado	Reducción medible del correo suplantado que alcanza al usuario

Iniciativa	Salvaguardas CIS v8.1	IG	Horizonte	Responsable	Dependencias	Resultado esperado
Defensas contra malware con gestión centralizada y análisis de medios removibles	10.1 a 10.7	IG1 / IG2	Mediano	Jefatura de TI/TO	Líneas base de configuración	Cobertura completa en TI y en las estaciones de ingeniería del entorno de control
Control de acceso y gestión de cuentas centralizados y basados en roles	5.5, 5.6, 6.6, 6.7, 6.8	IG2 / IG3	Mediano	Jefatura de TI/TO	Autenticación multifactor implantada y cuentas inventariadas	Accesos otorgados por rol, con revisión semestral documentada
Gestión de dispositivos portátiles de campo: bloqueo, borrado remoto y separación de espacios	4.10, 4.11, 4.12	IG2 / IG3	Mediano	Jefatura de TI/TO con Gerencia Técnica	Plataforma de gestión móvil adquirida	Dispositivos de cuadrillas administrados y recuperables ante pérdida
Inventario automatizado de software y lista de software autorizado	2.4, 2.5	IG2	Mediano	Jefatura de TI/TO	Sustitución de Windows 10 y software con soporte vigente	Software no autorizado detectado y bloqueado en la red de TI
Evaluación y monitoreo de proveedores de servicios	15.5, 15.6	IG3	Mediano	Cumplimiento con la Jefatura de Seguridad	Anexos de seguridad firmados en el corto plazo; se adelanta porque trata R-09 y R-14, riesgos Altos de E.05	Proveedores críticos evaluados antes de contratar y monitoreados con evidencia anual
Configuración segura de la infraestructura de aplicaciones y remediación de hallazgos de pruebas	16.7, 18.3	IG2	Mediano	Jefatura de Seguridad con Soluciones Ánfora y Vector Security	Anexo de seguridad del contrato del portal	Plantillas de configuración aprobadas y hallazgos de las pruebas de penetración remediados según su riesgo
Prevención de fuga de datos y registro de acceso a datos sensibles	3.13, 3.14, 8.6, 8.7, 8.8	IG2 / IG3	Largo	Jefatura de Seguridad de la Información	Bitácoras centralizadas y clasificación aplicada	Visibilidad del acceso y de la salida de datos de clientes
Defensa activa de red: prevención de intrusiones, control de puerto y filtrado de capa de aplicación	13.2, 13.5, 13.7, 13.8, 13.9, 13.10	IG2 / IG3	Largo	Jefatura de Seguridad de la Información	Monitoreo en régimen y umbrales ajustados	Bloqueo automatizado sin afectar la operación en tiempo real
Seguridad de aplicaciones: modelado de amenazas y validación de las medidas de seguridad	16.14, 18.4	IG3	Largo	Jefatura de Seguridad con Soluciones Ánfora y Vector Security	Monitoreo en régimen y programa de pruebas en curso	Diseño del portal revisado y controles verificados contra técnicas reales
Administración con recursos de cómputo dedicados y acceso remoto con AAA centralizado	12.5, 12.7, 12.8	IG2 / IG3	Largo	Jefatura de TI/TO	Control de acceso centralizado implantado	Administración de la infraestructura desde estaciones dedicadas y aisladas
Control de software: listas de scripts y bibliotecas autorizadas y capacitación por rol	2.7, 14.9	IG2 / IG3	Largo	Jefatura de TI/TO con Recursos Humanos	Inventario de software completo y programa general de concientización cerrado	Ejecución de software controlada y capacitación diferenciada por puesto

I.2 Estado esperado por horizonte

Salvaguardas del IG asignado operando al cierre de cada horizonte, contadas sobre el checklist de E.08 más las seis F.1 de E.07; al cierre del largo plazo operan las 153.

Cierre del horizonte	IG1 operando (de 56)	IG2 operando (de 74)	IG3 operando (de 23)	Total (de 153)
Hoy (estado de E.08)	1	13	4	18
Corto plazo · 30 de junio de 2027	44	28	6	78
Mediano plazo · 30 de junio de 2028	56	66	13	135
Largo plazo · 31 de diciembre de 2029	56	74	23	153

Hoy operan las 18 salvaguardas que E.08 registra como «existente» (la 9.1) o «cubierta por tercero» (17); las trece «existente parcial» cuentan cuando cierra la iniciativa que las completa. Cada horizonte suma las salvaguardas de sus iniciativas en la tabla I.1, incluidas las de las tablas F.1 de E.07. El IG1 queda completo al cierre del mediano plazo, porque doce de sus salvaguardas dependen de capacidades de ese horizonte: bitácoras centralizadas, respuesta a incidentes, protección de correo y contra malware, y protección de datos.

I.3 Tratamientos de E.05 sin salvaguarda CIS

Los riesgos que E.05 trata con un control de ISO/IEC 27002:2022 sin salvaguarda CIS aplicable se registran aquí, fuera del conteo de las 153.

Riesgo (E.05)	Control ISO/IEC 27002:2022	Iniciativa	Responsable	Horizonte	Resultado esperado
R-11 Acceso físico no controlado a subestaciones, armarios de comunicación y repetidores	7.11 Servicios de suministro	Planta de respaldo y prueba trimestral en el repetidor de radio sin respaldo de energía (SPOF-07)	Gerencia de Operaciones de Red	Corto	Los tres repetidores del radio troncalizado con respaldo de energía probado cada trimestre
R-11 Acceso físico no controlado a subestaciones, armarios de comunicación y repetidores	7.2 Entrada física y 7.4 Monitoreo de la seguridad física	Control de acceso y monitoreo físico de las subestaciones, los armarios de comunicación y los repetidores	Gerencia Técnica con la Jefatura de Seguridad de la Información	Mediano	Todo ingreso a las instalaciones de la red registrado, autorizado y monitoreado

E.05 trata R-11 con el control 12 y con controles físicos; estas dos iniciativas cubren la parte física, quedan fuera del conteo de las 153 salvaguardas y se costean en la revisión trimestral del programa.

Supuestos declarados en este entregable

Solo se declara como supuesto lo que ni el perfil del catálogo ni la ficha de datos del cliente traen: un dato que la ficha trae nunca se sustituye por un supuesto. Cada supuesto lleva un identificador global y correlativo en todo el proyecto (S-01, S-02…): el entregable continúa la numeración del anterior y E.11 los consolida en su Anexo A. Cuando el entregable no declara supuestos, la primera fila lo dice.

ID (S-nn, numeración global)	Supuesto	Fundamento u origen
—	Sin supuestos nuevos en este entregable.	El presupuesto de 2028 y 2029 usa el supuesto S-14 de BIA_P06; la fecha de arranque del programa, el 4 de enero de 2027, es un dato de la ficha.

Horizontes, criterio de progresión y costo

Horizonte	Iniciativas	Salvaguardas que cierra	Inversión anual estimada	Criterio de entrada
Corto plazo (0–6 meses): 4 de enero a 30 de junio de 2027	13	60	USD 392 000 en las nueve iniciativas cotizadas; las cuatro que se añaden, por cotizar	Cierre de las brechas IG1 detectadas en E.08 y estabilización de los seis controles desarrollados en E.07
Mediano plazo (6–18 meses): 1 de julio de 2027 a 30 de junio de 2028	11	57	USD 265 000 en las ocho iniciativas cotizadas; las tres que se añaden, por cotizar	Salvaguardas IG2 del baseline pendientes; cada iniciativa entra cuando sus dependencias del corto plazo están cubiertas
Largo plazo (18–36 meses): 1 de julio de 2028 a 31 de diciembre de 2029	5	18	USD 180 000	Salvaguardas IG3 del baseline, hasta completar las 153 del Grupo de Implementación asignado

Las 135 salvaguardas que no operan hoy —89 del checklist de E.08 y las 46 de las tablas F.1 de E.07— se distribuyen en los tres horizontes: 60 en el corto plazo, 57 en el mediano y 18 en el largo; las 18 restantes del baseline ya operan (tabla I.2). La inversión cotizada del primer año, USD 392 000, cabe dentro del presupuesto anual de USD 480 000 que asigna la ficha de datos del cliente y que la dirección comprometió en E.02, y deja USD 88 000 para la operación del programa y para las cuatro iniciativas que esta versión añade al corto plazo. La gestión de cuentas y la gestión de datos se ejecutan con las tres plazas del programa; la migración a FortiOS 7.4 y la sustitución de Windows 10 se cotizan antes de iniciarlas, porque la ficha no cuantifica su costo ni el número de estaciones del parque heredado. En el escenario mínimo del supuesto S-14 —USD 300 000— el equipo recomienda mantener las cuatro primeras iniciativas del corto plazo y desplazar al mediano plazo la gestión de dispositivos portátiles y la protección de correo, porque son las de menor efecto sobre los riesgos Críticos.

El orden del corto plazo sigue la dependencia técnica y el riesgo residual: el respaldo encabeza el programa porque sin él cualquier incidente sobre el entorno de control excede el período máximo tolerable de cuatro horas, aun cuando la segmentación tenga mayor efecto sobre la probabilidad. La segunda iniciativa, la segmentación, habilita técnicamente al monitoreo, que por eso aparece en el mediano plazo y no antes.

Trazabilidad del roadmap

Riesgo de E.05	Iniciativa que lo reduce	Horizonte en que el residual alcanza el nivel declarado
R-01 Crítico	Segmentación TI–OT · Monitoreo de la red OT · Respaldo con copia aislada	Corto para el residual Medio; mediano para la detección en régimen
R-02 Crítico	Concentrador de acceso para proveedores · Anexos de seguridad en contratos	Corto
R-07 Crítico	Autenticación multifactor · Control de acceso centralizado · Concientización	Corto, con consolidación en el mediano

Riesgo de E.05	Iniciativa que lo reduce	Horizonte en que el residual alcanza el nivel declarado
R-03, R-10 Altos	Inventario de activos con descubrimiento pasivo · Centralización de bitácoras	Corto e inicio del mediano
R-12 Alto	Gestión de vulnerabilidades con ventanas para OT	Corto
R-06 Alto	Respaldo con prueba de restauración	Corto
R-05, R-13 Altos y Medio	Protección de datos · Seguridad de aplicaciones con el proveedor	Mediano y largo
R-04, R-08, R-09, R-11, R-14 Altos	Configuración segura · Concientización · Gestión de proveedores · Medidas físicas de la tabla I.3	Corto y mediano

Al cierre del corto plazo ningún riesgo Crítico o Alto conserva su nivel inherente, y al cierre del largo plazo ENSA completa las 153 salvaguardas del IG3 que el catálogo le asigna.